

Actividad 09

Traversal sequences stripped non-recursively

Bypass de filtro — strip no recursivo

Nombre: Tristán Rivera Magdalena Yesenia

Matrícula: 174702

Materia / Grupo: CNO IV — Programación WAP · T37A

Profesor: Servando López Contreras

Herramienta: Burp Suite Community Edition

URL: <https://portswigger.net/web-security/file-path-traversal/lab-sequences-stripped-non-recursively>

OBJETIVO

Evadir un filtro que elimina las secuencias `../` del input, pero solo aplica esa limpieza una vez (no de forma recursiva).

EXPLICACIÓN TÉCNICA DE LA VULNERABILIDAD

El servidor busca y borra `../` del string en una sola pasada. Si se construye un input donde, al quitar el `../` del centro, sobrevive un nuevo `../` completo, el filtro nunca lo vuelve a analizar y la secuencia maliciosa llega intacta a la capa de archivos.

PROCEDIMIENTO PASO A PASO

1. Activar Intercept on en Burp y hacer clic en un producto.
2. Interceptar la request de imagen y mandarla a Repeater.
3. Construir el payload usando `....//` en vez de `../`.
4. Enviar y verificar que, tras el strip de un solo paso del servidor, el resultado sigue subiendo directorios.
5. Confirmar el Response y el badge "Lab solved".

PAYLOAD UTILIZADO

```
GET /image?filename=....//....//....//etc/passwd HTTP/2
```

Al quitarle un `../` del centro de cada `....//`, queda exactamente `../`. Como el filtro no vuelve a pasar sobre el string ya "limpio", la secuencia resultante sí funciona y sube tres niveles de directorio.

MITIGACIÓN RECOMENDADA

Aplicar el filtrado de secuencias de forma recursiva hasta que ya no queden cambios (o mejor, evitar el enfoque de "limpiar strings" por completo y validar la ruta canónica final, que es inmune a este tipo de bypass).

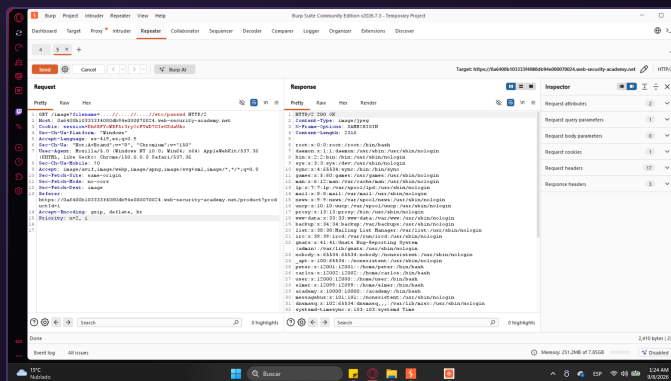


Figura 1. Request en Burp Repeater con el payload + Response con /etc/passwd

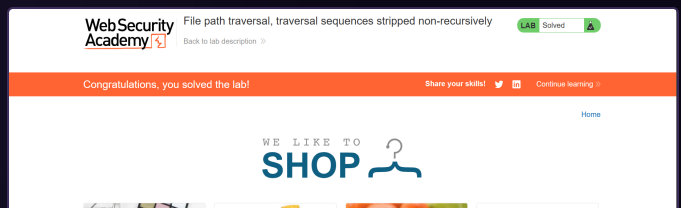


Figura 2. Confirmación "Lab solved" en PortSwigger Web Security Academy